

个人AI工作台 Outlook 对接操作手册

文档版本：1.0

适用项目：个人AI工作台

适用场景：Windows 本地开发/运行，前端端口 5174，后端端口 8787

更新日期：2026-08-27

目录

- [1. 文档说明](#)
- [2. 对接原理与数据流](#)
- [3. 前置准备](#)
- [4. 在 Microsoft Entra 中注册应用](#)
- [5. 配置工作台环境变量](#)
- [6. 启动工作台并检查配置](#)
- [7. 授权并连接 Outlook](#)
- [8. 验证首次同步](#)
- [9. 日常邮件处理](#)
- [10. 同步机制与数据安全](#)
- [11. 断开、重连与彻底重置](#)
- [12. 故障排查](#)
- [13. 最终验收清单](#)
- [14. Microsoft 官方参考资料](#)

1. 文档说明

1.1 目标读者

本手册面向以下两类人员：

- 系统管理员或部署人员**：负责 Microsoft Entra 应用注册、API 权限、环境变量和服务启动。
- 工作台使用者**：负责使用自己的 Outlook 账号完成授权，并在行动中心中处理同步后的邮件。

1.2 对接后可以做什么

完成对接后，工作台可以：

- 读取当前登录用户 Outlook **收件箱** 中的邮件；
- 使用 DeepSeek 对邮件进行摘要、行动分类、优先级和截止时间判断；
- 将邮件划分为“需要行动”“仅供知晓”“无法判断”和“归档”；
- 人工纠正 AI 分类结果；
- 将需要行动的邮件转换为工作台待办；
- 根据邮件内容生成回复草稿，供用户复制到 Outlook 后人工确认并发送；
- 每 15 分钟自动执行增量同步，也可以手动立即同步。

1.3 当前实现的边界

- 授权方式是 OAuth 2.0 授权码流程 + PKCE，应用属于**公共客户端**。
- 不需要也不应配置 Client Secret（客户端密码）。
- Microsoft Graph 只申请委托式 Mail.Read 权限。
- 工作台不会修改、删除或发送 Outlook 邮件。
- 回复草稿不会自动写入 Outlook 草稿箱，也不会自动发送。
- 当前 Outlook 分类链路实际依赖 DEEPSEEK_API_KEY；即使项目的其他 AI 功能支持别的提供商，Outlook 对接仍必须配置 DeepSeek。
- 本手册以本地开发模式为准。如果修改端口、域名或部署方式，必须同步修改 Microsoft Entra 中的重定向 URI 和 .env。

[配图占位 01：工作台 Outlook 对接全流程概览——展示 Entra 注册、环境变量、用户授权、邮件同步和行动中心五个阶段；建议图注“Outlook 对接实施流程”；本图不应出现任何真实密钥或账号。]

2. 对接原理与数据流

2.1 数据流



2.2 授权范围

工作台在授权请求中使用以下范围：

范围	用途	是否增加邮箱写权限
Mail.Read	读取当前登录用户的邮件和正文	否
offline_access	获取刷新令牌，以使用户不在页面时继续定时同步	否
openid	完成 OpenID Connect 登录	否
profile	获取基本登录身份声明	否

Mail.Read 必须配置为 **Delegated permissions（委托的权限）**，不要选成 **Application permissions（应用程序权限）**。委托权限只代表当前登录用户访问自己的邮箱；应用程序权限会形成完全不同且权限更高的后台访问模式，不符合本项目实现。

2.3 多租户与单租户

项目默认配置为：

```
1 | OUTLOOK_ENTRA_TENANT_ID=common
```

这表示授权请求使用 Microsoft 公共租户入口。推荐的 Entra“支持的帐户类型”为：

- 团队成员来自多个 Microsoft Entra 组织：选择“任何组织目录中的帐户/多个 Entra ID 租户”。
- 还需要支持个人 Outlook.com、Hotmail 等账号：选择“任何 Entra ID 租户中的帐户和个人 Microsoft 帐户”。
- 只允许本公司租户：可以选择单租户，但应把 `OUTLOOK_ENTRA_TENANT_ID` 改为该租户的 Directory (tenant) ID。

注意：支持的帐户类型必须与实际用户范围一致。若 Entra 应用只允许组织账号，个人 Microsoft 账号将无法登录。

3. 前置准备

开始前请确认以下条件。

3.1 Microsoft 侧

- 有一个可以正常登录 Outlook 的 Microsoft 365 工作/学校账号，或与所选帐户类型匹配的个人 Microsoft 账号。
- 有权限在目标 Microsoft Entra 租户中创建“应用注册”。
- 如果组织禁止普通用户同意应用权限，需要联系租户管理员完成管理员同意。

3.2 工作台侧

- 已安装 Node.js 和 npm。
- 已取得项目代码并进入项目根目录。
- 已准备可用的 DeepSeek API Key。
- 端口 `5174` 和 `8787` 未被其他程序占用，或已明确规划替代端口。

3.3 网络侧

运行工作台的电脑需要访问：

- `https://login.microsoftonline.com`
- `https://graph.microsoft.com`
- `https://api.deepseek.com`，或 `.env` 中配置的 DeepSeek 服务地址

如果公司网络使用代理，工作台会读取 `HTTP_PROXY`、`HTTPS_PROXY` 或 `ALL_PROXY`。启动时会探测代理是否可以访问 Microsoft 登录端点；代理不可用但直连可用时会自动回退直连。

3.4 建议先记录的参数

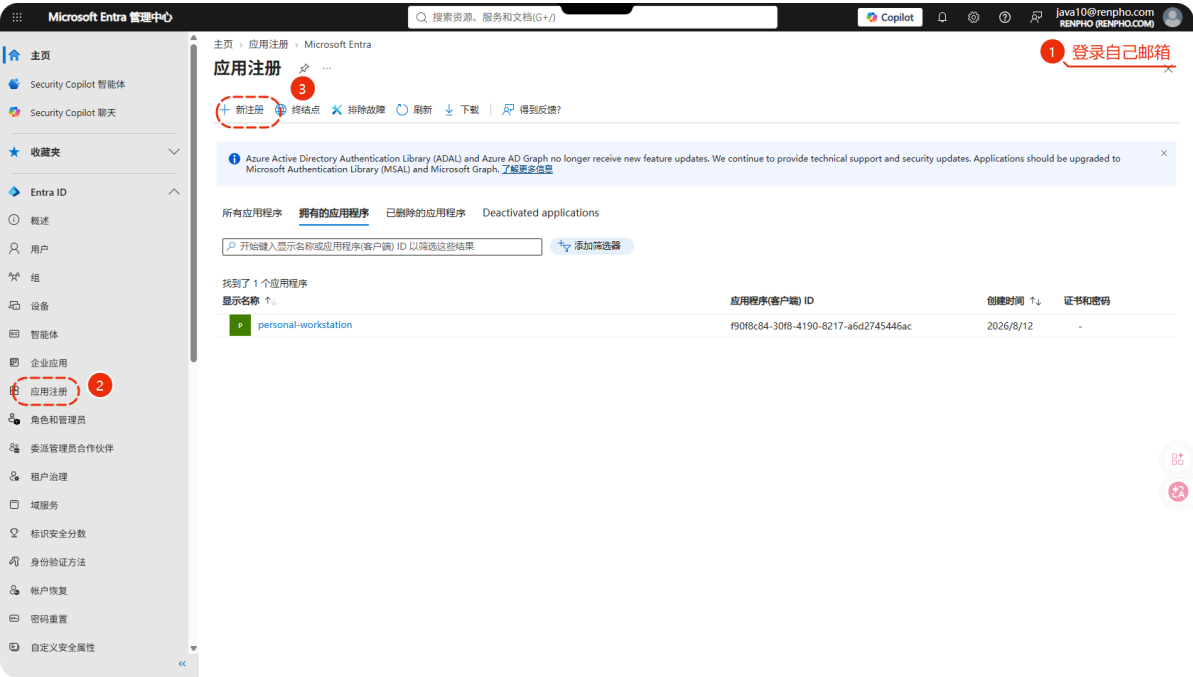
参数	示例/说明
应用名称	个人AI工作台-Outlook
前端地址	http://127.0.0.1:5174
后端地址	http://127.0.0.1:8787
OAuth 回调地址	http://127.0.0.1:5174/api/outlook/oauth/callback
租户模式	默认 common
Graph 权限	委托式 Mail.Read

4. 在 Microsoft Entra 中注册应用

Microsoft Entra 管理中心的中文菜单名称可能因租户界面版本略有差异。若界面显示英文，可按照括号中的英文名称查找。

4.1 登录并选择租户

1. 打开 [Microsoft Entra 管理中心](#)。
2. 使用有权创建应用注册的管理员或开发人员账号登录。
3. 如果账号可以访问多个租户，点击页面顶部的目录/设置入口。
4. 切换到实际用于创建工作台应用的租户。
5. 确认页面右上角显示的租户名称正确后再继续。



4.2 创建应用注册

1. 在左侧导航中进入 **Entra ID**。
2. 选择 **应用注册 (App registrations)** 。
3. 点击 **新注册 (New registration)** 。
4. 在“名称”中输入易识别的名称，例如：

1 | 个人AI工作台-Outlook

5. 在“支持的帐户类型 (Supported account types)”中选择适合团队的范围：
 - 默认建议：**任何组织目录中的帐户 (多租户)** ；
 - 如果还要允许个人 Outlook/Hotmail 账号，选择同时支持个人 Microsoft 帐户的选项；
 - 如果仅限本公司成员，选择单租户，并在后续 `.env` 中填写租户 ID。
6. “重定向 URI”可以暂时留空，稍后在“身份验证”页面精确配置。
7. 点击 **注册 (Register)** 。



4.3 记录应用 ID

注册完成后会自动进入应用的“概述 (Overview)”页面。

1. 找到 **应用程序(客户端) ID (Application (client) ID)** 。
2. 点击复制，并暂存在安全位置。
3. 如果采用单租户模式，同时复制 **目录(租户) ID (Directory (tenant) ID)** 。
4. 不要复制“对象 ID”作为客户端 ID，两者用途不同。

后续对应关系如下：

- 1 | `OUTLOOK_ENTRA_CLIENT_ID=<应用程序(客户端) ID>`
- 2 | `OUTLOOK_ENTRA_TENANT_ID=common`

单租户时：

1 | OUTLOOK_ENTRA_TENANT_ID=<目录(租户) ID>



4.4 添加移动和桌面应用程序平台

1. 在当前应用左侧的“管理 (Manage)”区域选择 **身份验证 (Authentication)**。
2. 点击 **添加平台 (Add a platform)**。
3. 选择 **移动和桌面应用程序 (Mobile and desktop applications)**。
4. 在“自定义重定向 URI (Custom redirect URIs)”中添加以下完整地址：

1 | `http://127.0.0.1:5174/api/outlook/oauth/callback`

5. 点击 **配置 (Configure)** 或 **保存 (Save)**。
6. 返回身份验证页面，确认该 URI 已显示在“移动和桌面应用程序”平台下。

必须逐字符一致地使用上述地址，重点检查：

- 协议是 `http`；
- 主机是 `127.0.0.1`，不是 `localhost`；
- 端口是 `5174`；
- 路径是 `/api/outlook/oauth/callback`；
- 末尾没有额外 `/`。

特别说明：Microsoft 官方对一般桌面系统浏览器应用推荐 `http://localhost`，但本项目代码实际发送的是包含路径和端口的 `http://127.0.0.1:5174/api/outlook/oauth/callback`。
Entra 中必须登记与 `.env` 和实际授权请求一致的项目 URI，否则会出现 `AADSTS50011`。

4.5 启用公共客户端流

设备码授权要求应用被标识为公共客户端。

1. 仍在 **身份验证 (Authentication)** 页面向下滚动。
2. 找到 **高级设置 (Advanced settings)** 。
3. 将 **允许公共客户端流 (Allow public client flows)** 设置为 **是 (Yes)** 。
4. 点击页面顶部或底部的 **保存 (Save)** 。
5. 刷新页面，确认设置仍为“是”。

[配图占位 07：身份验证高级设置——框选“允许公共客户端流 = 是”；建议图注“启用设备码授权”；不包含账号信息。]

4.6 配置 Microsoft Graph 权限

1. 在应用左侧选择 **API 权限 (API permissions)** 。
2. 点击 **添加权限 (Add a permission)** 。
3. 选择 **Microsoft Graph**。
4. 选择 **委托的权限 (Delegated permissions)** 。
5. 搜索 `Mail.Read`。
6. 勾选 **Mail.Read — Read user mail / 读取用户邮件**。
7. 点击 **添加权限 (Add permissions)** 。
8. 返回权限列表，确认权限类型为“委托”，而不是“应用程序”。

项目的授权请求会主动携带 `openid profile offline_access Mail.Read`。`offline_access` 用于获取刷新令牌，不会扩大邮箱读写权限。



4.7 是否需要管理员同意

Microsoft 的权限参考中，委托式 `Mail.Read` 默认不要求管理员同意；但组织可以通过用户同意策略、条件访问或企业应用策略阻止普通用户自行授权。

如果用户授权时看到“需要管理员批准”：

1. 不要改用权限更高的 Application 权限绕过限制。
2. 联系租户管理员检查企业应用和用户同意策略。
3. 由管理员在“API 权限”页面点击“代表 <租户名称> 授予管理员同意”，或按组织审批流程批准。
4. 管理员同意后，让用户重新发起工作台授权。

4.8 不要创建 Client Secret

本项目使用 PKCE 公共客户端流程，令牌交换请求中不会发送 Client Secret。因此：

- 不需要进入“证书和密码”创建客户端密码；
- 不要把任何 Client Secret 写入 `.env`；
- 如果已经误创建，可以在确认没有其他系统使用后按组织安全流程删除。

5. 配置工作台环境变量

以下操作都在项目根目录执行。

5.1 复制环境变量模板

PowerShell：

```
1 | Copy-Item -LiteralPath .env.example -Destination .env
```

如果 `.env` 已存在，请先备份，不要直接覆盖：

```
1 | Copy-Item -LiteralPath .env -Destination .env.backup
```


[配图占位 10: 项目根目录文件列表——标注 `.env.example` 和新建的 `.env`；建议图注“创建本地环境配置”；截图中不得展示 `.env` 内容。]

5.2 生成 Outlook 本地加密密钥

`OUTLOOK_TOKEN_ENCRYPTION_KEY` 必须是 **32 字节随机数据的 Base64 字符串**。

推荐使用项目所需的 Node.js 生成：

```
1 node -e  
  "console.log(require('node:crypto').randomBytes(32).toString('base64'))"
```

也可以仅使用 PowerShell/.NET：

```
1 $keyBytes = New-Object byte[] 32  
2 [System.Security.Cryptography.RandomNumberGenerator]::Fill($keyBytes)  
3 [Convert]::ToBase64String($keyBytes)
```

如果当前 PowerShell/.NET 版本不支持 `RandomNumberGenerator.Fill`，使用：

```
1 $keyBytes = New-Object byte[] 32  
2 $rng = [System.Security.Cryptography.RandomNumberGenerator]::Create()  
3 $rng.GetBytes($keyBytes)  
4 $rng.Dispose()  
5 [Convert]::ToBase64String($keyBytes)
```

复制输出结果，写入 `.env`。不要把生成结果粘贴到聊天、工单、截图或版本库。

重要：首次连接 Outlook 后，不要随意更换此密钥。`.local/outlook/state.enc.json` 使用该密钥进行 AES-256-GCM 加密。密钥丢失或改变后，原有令牌、授权状态和本地 Outlook 邮件状态无法解密。

5.3 填写最小可用配置

打开 `.env`，至少完成以下内容：

```
1 # 服务基础  
2 PORT=8787  
3 PUBLIC_BASE_URL=http://localhost:5174  
4 CORS_ORIGIN=http://localhost:5174  
5  
6 # Outlook 邮件分类当前实际使用 DeepSeek  
7 AI_PROVIDER=deepseek  
8 DEEPSEEK_API_KEY=<填写真实 DeepSeek API Key>  
9 DEEPSEEK_BASE_URL=https://api.deepseek.com  
10 DEEPSEEK_MODEL=deepseek-chat  
11  
12 # Outlook / Microsoft Graph  
13 OUTLOOK_ENTRA_CLIENT_ID=<填写 Application (client) ID>  
14 OUTLOOK_ENTRA_TENANT_ID=common  
15 OUTLOOK_OAUTH_REDIRECT_URI=http://127.0.0.1:5174/api/outlook/oauth/callback  
16 OUTLOOK_TOKEN_ENCRYPTION_KEY=<填写刚生成的 32 字节 Base64 密钥>  
17  
18 # 接入真实数据时关闭演示数据
```

不要保留以下模板值：

```
1 | OUTLOOK_TOKEN_ENCRYPTION_KEY=replace-with-32-byte-base64-key
```

该字符串不是有效的 32 字节 Base64 密钥，工作台会将 Outlook 判断为“未配置”。

5.4 配置项说明

变量	必填	说明
OUTLOOK_ENTRA_CLIENT_ID	是	Entra 应用的 Application (client) ID
OUTLOOK_ENTRA_TENANT_ID	是	默认 <code>common</code> ；单租户时填写 Directory (tenant) ID
OUTLOOK_OAUTH_REDIRECT_URI	是	必须与 Entra 中登记的回调地址一致
OUTLOOK_TOKEN_ENCRYPTION_KEY	是	32 字节 Base64 密钥，用于加密 Outlook 本地状态
DEEPSEEK_API_KEY	是	Outlook 邮件分类的模型凭据
DEEPSEEK_BASE_URL	否	默认 <code>https://api.deepseek.com</code>
DEEPSEEK_MODEL	否	默认 <code>deepseek-chat</code>
USE_DEMO_DATA	建议	接入真实数据时设为 <code>false</code> ，避免混入演示数据
PORT	否	后端端口，默认 <code>8787</code>
WORKBENCH_PORT	否	前端端口，默认 <code>5174</code>

5.5 端口变更规则

如果前端端口不是 `5174`，必须同时修改：

1. `WORKBENCH_PORT`；
2. `PUBLIC_BASE_URL` 和 `CORS_ORIGIN`；
3. `OUTLOOK_OAUTH_REDIRECT_URI`；
4. Entra“身份验证”中的重定向 URL。

例如改成 `5180`：

```
1 | WORKBENCH_PORT=5180
2 | PUBLIC_BASE_URL=http://localhost:5180
3 | CORS_ORIGIN=http://localhost:5180
4 | OUTLOOK_OAUTH_REDIRECT_URI=http://127.0.0.1:5180/api/outlook/oauth/callback
```

Entra 中也必须登记：

```
1 http://127.0.0.1:5180/api/outlook/oauth/callback
```

```
22 # CLAUDE_MODEL=claude-sonnet-4
23 # OLLAMA_BASE_URL=http://127.0.0.1:11434
24 # OLLAMA_MODEL=qwen2.5:14b
25
26 # ===== Outlook / Microsoft Graph (多租户公共客户端, PKCE 无 secret) =====
27 # 变量名与 GitHub 仓库 WangYehen/my-work-bench 保持一致
28 # 在 Azure Entra 注册「任何组织目录中的帐户(多租户)」应用, 无需 Client Secret
29 # 添加平台 "Mobile and desktop applications", 并注册下面这个重定向 URI
30 # (前端 5174 经 Vite 代理 /api 转发到后端 8787, 由后端完成令牌交换; 与仓库 5174 一致, Azure 无需改动)
31 # 所需权限范围: Mail.Read + offline_access
32 WORKBENCH_PORT=5174
33 OUTLOOK_ENTRA_TENANT_ID=9817287f15c5ce
34 OUTLOOK_ENTRA_CLIENT_ID=f90f8c843446ac
35 OUTLOOK_OAUTH_REDIRECT_URI=http://127.0.0.1:5174/api/outlook/oauth/callback
36 # Generate a 32-byte Base64 value; it encrypts local Outlook state and tokens.
37 OUTLOOK_TOKEN_ENCRYPTION_KEY=pivhLKrcINKHcEaq+PodFf7M=
38
39 # ===== 钉钉 (企业内部应用) =====
40 # 在钉钉开发者后台创建企业内部应用, 并"正好"注册下面这个重定向 URI
41 # (前端 5174 经 Vite 代理 /oauth 转发到后端 8787, 由后端完成令牌交换)
42 # 所需权限: 日志(read)、日程(read)、通讯录成员(read)
43 DINGTALK_CLIENT_ID=dingle187dxg3
44 DINGTALK_CLIENT_SECRET=n_3Y2iTykmdaC4iQC3hc-5cFh7vFpgZ
45 DINGTALK_REDIRECT_URI=http://127.0.0.1:5174/oauth/dingtalk/callback
46 # 当前主管在钉钉的用户 ID (用于圈定下属与团队日志范围)
47 DINGTALK_MANAGER_USER_ID=163271901
48
49 # ===== AI HOT 热点 (公开匿名 API, 无需密钥) =====
50 AI_HOT_ORIGIN=https://aihot.virxact.com
51
52 # ===== 演示数据兜底 =====
53 # 未配置任何外部服务时, 是否用合成数据演示界面 (true/false)
54 # 接入真实凭据后请改为 false, 否则演示数据会与真实数据混合/覆盖
55 USE_DEMO_DATA=false
```

6. 启动工作台并检查配置

6.1 安装依赖

首次运行时, 在项目根目录执行:

```
1 npm install
```

6.2 启动前后端

```
1 npm run dev
```

该命令会同时启动:

- 前端: `http://127.0.0.1:5174`
- 后端 API: `http://127.0.0.1:8787`

启动后不要立即关闭终端, 后续授权回调和同步都依赖后端进程持续运行。

6.3 检查启动日志

正常情况下应看到类似信息:

```
1 [net] 未配置 HTTP 代理, 对外请求直连。
2 [team-workbench] API listening on http://127.0.0.1:8787
```

如果配置了代理, 则可能看到:

```
1 [net] 对外请求经代理 <主机:端口> (钉钉域名直连)。
```

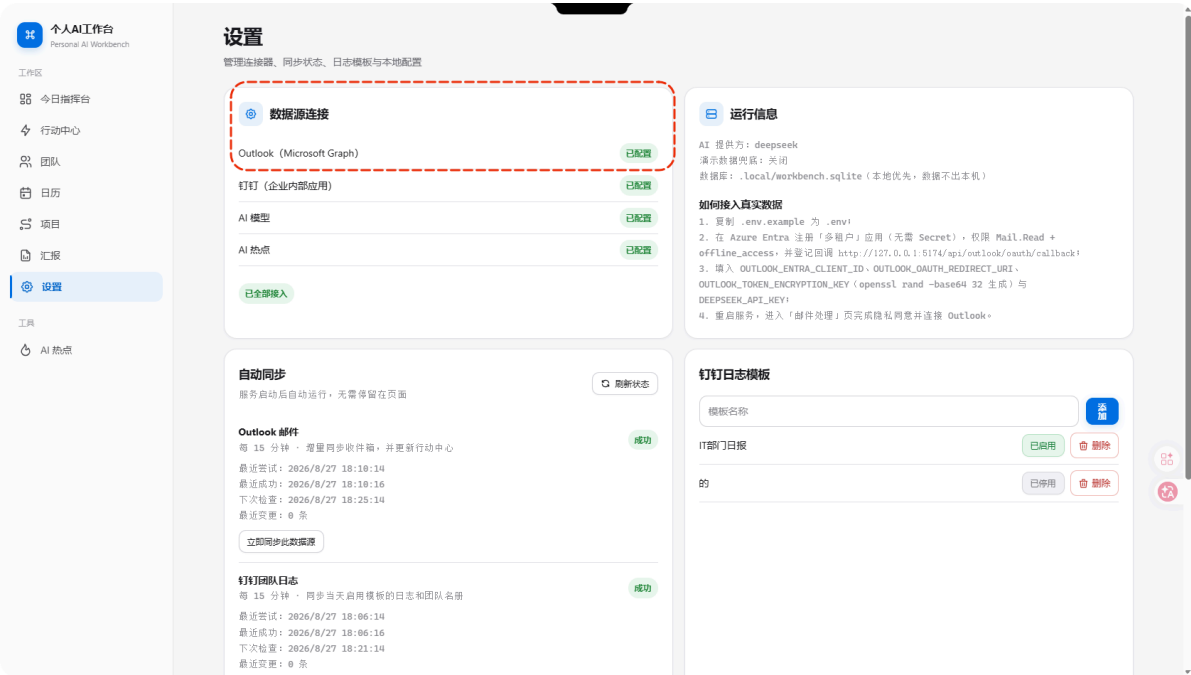
如果看到“代理与直连均无法访问 Microsoft”, 应先解决网络问题, 再进行授权。

6.4 检查系统设置页

1. 浏览器打开 `http://127.0.0.1:5174/settings`。
2. 在“数据源连接”中查看 Outlook (Microsoft Graph) 和 AI 模型状态。
3. Outlook 若显示“未配置”，点击“连接 Outlook”会进入配置/授权页面。
4. 如果 Outlook 已显示“已配置”但尚未授权，可直接打开：

1 | `http://127.0.0.1:5174/mail-setup`

当前版本的“设置”页只会在 Outlook 配置不完整时显示“连接 Outlook”按钮；因此，环境变量已经齐全但尚未完成用户授权时，直接访问 `/mail-setup` 是最明确的入口。



6.5 修改 .env 后必须重启

后端启动时读取 `.env`。修改客户端 ID、租户、回调地址、DeepSeek Key 或加密密钥后，需要：

1. 在运行终端按 `Ctrl+C` 停止服务；
2. 再次执行 `npm run dev`；
3. 刷新浏览器页面。

项目当前会让 `.env` 覆盖启动进程中已有的同名环境变量，以减少旧环境变量干扰；但仍必须重启进程才能重新加载。

7. 授权并连接 Outlook

7.1 进入授权页面

打开：

1 | `http://127.0.0.1:5174/mail-setup`

页面会先显示“连接 Outlook 前的隐私确认”。确认页面没有列出缺失配置项。

[配图占位 13: 工作台 Outlook 隐私确认页面——标注隐私说明、确认复选框和两种连接按钮；建议图注“连接前确认数据处理方式”；请勿展示真实邮件。]

7.2 阅读并确认隐私说明

授权前应让实际邮箱使用者理解：

- 工作台将读取近 7 天收件箱作为首次同步范围；
- 邮件文本会发送给 DeepSeek，用于生成分类、摘要、行动建议和截止时间；
- 工作台申请 `Mail.Read`，不会修改 Outlook 邮箱；
- 工作台会在本机保存加密的 Outlook 连接和分类状态；
- AI 回复草稿只用于复制，不会自动发送。

勾选“我理解并同意上述处理方式”。未勾选时连接按钮不可用。

7.3 方式一：标准浏览器授权（推荐）

1. 点击 **同意并连接 Outlook**。
2. 工作台向后端登记隐私同意，并生成一次性 PKCE 授权会话。
3. 浏览器跳转到 Microsoft 登录页面。
4. 选择要接入的 Outlook 账号。
5. 按组织要求完成密码、多因素认证或条件访问验证。
6. 在 Microsoft 权限确认页核对：应用请求读取当前用户邮件，并保持已授予的访问权限。
7. 点击 **接受/同意**。
8. Microsoft 将浏览器回跳到：

```
1 | http://127.0.0.1:5174/api/outlook/oauth/callback
```

9. Vite 将 `/api` 请求代理到本地后端 `8787`，后端交换并加密保存令牌。
10. 完成后浏览器返回工作台邮件页面，并触发首次同步。

[配图占位 14: Microsoft 账号选择页面——展示选择工作账号的位置；建议图注“选择需要同步的 Outlook 账号”；账号邮箱、头像和租户信息必须打码。]

[配图占位 15: Microsoft 权限同意页面——突出应用名称和“读取你的邮件”权限；建议图注“确认最小授权范围”；用户邮箱和组织名称必须打码。]

7.4 方式二：设备码授权

当本机浏览器无法打开 Microsoft 登录页、标准授权无法回跳 `127.0.0.1`，或出现 `ERR_CONNECTION_CLOSED` 时，可以使用设备码。

1. 在隐私确认页勾选同意。
2. 点击 **设备码连接**。
3. 页面会显示验证网址和一次性用户码。
4. 在本机、手机或另一台可访问 Microsoft 登录服务的设备上打开页面显示的网址，通常为：

```
1 | https://microsoft.com/devicelogin
```

5. 输入工作台页面中的用户码。
6. 使用要连接的 Outlook 账号登录。
7. 阅读并同意权限请求。
8. 回到工作台页面，不要刷新或关闭页面。
9. 工作台会按 Microsoft 返回的间隔自动轮询授权结果。
10. 授权成功后，页面会自动显示连接成功并开始首次同步。

[配图占位 16：工作台设备码区域——突出验证网址、用户码和等待提示；建议图注“获取设备码并在其他设备授权”；截图中的用户码必须在失效后再使用，或直接打码。]

[配图占位 17：Microsoft 设备登录页面——标注输入用户码的位置；建议图注“输入设备码完成授权”；不得包含真实有效用户码。]

设备码有有效期。若提示过期、会话不存在或授权被拒绝，请回到工作台重新点击“设备码连接”，获取新代码。

7.5 授权过程中的注意事项

- 发起标准浏览器授权后应在 10 分钟内完成；超时后必须重新发起。
- 回调发生时，前端和后端都必须仍在运行。
- 不要在授权中途切换 `.env`、端口或客户端 ID。
- 浏览器回跳失败不代表设备码授权也会失败，可以直接改用设备码。
- 如果 Microsoft 显示的应用名称或权限与本手册不一致，应停止授权并联系管理员核对应用注册。

8. 验证首次同步

8.1 查看连接状态

授权成功后进入“行动中心 → 邮件”，或直接打开：

```
1 | http://127.0.0.1:5174/actions?tab=email
```

页面应显示：

- “已连接 Outlook”或等价连接状态；
- 邮件队列及数量；
- 最近同步时间；
- “立即同步”按钮。

[配图占位 18：行动中心“邮件”页全景——框选连接/同步状态、四个队列和邮件详情区域；建议图注“Outlook 邮件行动中心”；邮件主题、发件人和正文必须脱敏。]

8.2 首次同步规则

首次同步会：

1. 读取收件箱中最近 7 天的邮件；
2. 按收到时间从新到旧分页获取；
3. 单次最多检查 500 封；

- 4. 清洗邮件正文，去除 HTML 标签并尽量截断历史回复；
- 5. 调用 DeepSeek 生成分类结果；
- 6. 将邮件放入对应队列；
- 7. 保存最新同步游标，为后续增量同步做准备。

首次同步耗时取决于邮件数量、网络速度和 DeepSeek 响应速度。不要在同步过程中连续点击“立即同步”。服务会等待正在执行的同步结束后再处理下一次请求。

8.3 首次同步验收

至少抽查 3 ~ 5 封最近邮件：

- 发件人和主题与 Outlook 一致；
- “打开原邮件”能够跳到正确邮件；
- AI 摘要与邮件内容基本一致；
- 行动分类、优先级和截止时间可理解；
- 发现误判时可以人工纠正；
- 页面没有显示“上次失败”或网络错误。

如果授权成功但没有邮件，请先点击“立即同步”，再检查 Outlook 收件箱最近 7 天是否确实有邮件。

9. 日常邮件处理

9.1 四个邮件队列

队列	含义	建议操作
需要行动	AI 判断需要回复、审批、确认、提交或在期限前处理	转待办、生成回复草稿、完成后归档
仅供知晓	暂无明确行动要求的信息类邮件	阅读后标记已处理
无法判断	AI 置信度不足或分类失败，需要人工判断	改为“需要行动”或“仅供知晓”
归档	已处理、忽略或已转为待办的本地记录	回查历史，必要时恢复

这些队列是工作台的本地处理状态，不会移动 Outlook 邮箱中的邮件文件夹。

9.2 优先级与截止时间

优先级	含义	典型场景
P0	紧急且应优先处理	已逾期、明确要求立即处理、严重阻塞
P1	近期需要处理	有明确行动要求或近期截止时间
P2	优先级较低	暂无紧迫期限或影响较小

截止来源可能是：

- **explicit**：邮件中有明确日期或时间；
- **inferred**：AI 根据上下文推断；
- **none**：未发现截止时间。

AI 置信度和截止时间只是辅助判断。涉及付款、合同、权限、客户承诺等高风险事项时，应打开原邮件人工确认。

9.3 立即同步

1. 进入“行动中心 → 邮件”。
2. 点击 **立即同步**。
3. 等待按钮恢复可点击状态。
4. 检查队列数量和最近同步时间是否更新。

后端也会每 15 分钟自动增量同步。自动同步只在工作台后端持续运行时有效。

[配图占位 19：邮件页同步状态——突出“立即同步”、最近同步时间和自动同步说明；建议图注“手动触发 Outlook 同步”；邮件内容必须脱敏。]

9.4 查看和打开原邮件

1. 在左侧邮件列表选择一封邮件。
2. 在右侧查看 AI 行动建议、摘要、优先级和截止时间。
3. 点击 **打开原邮件**。
4. 浏览器会使用 Microsoft Graph 返回的 **webLink** 打开 Outlook；若没有链接，会按主题搜索 Outlook。

9.5 纠正 AI 分类

对“无法判断”的邮件，可以直接选择：

- **设为需要行动**；
- **设为仅供知晓**。

在完整邮件处理页面中还可以调整行动类型、行动说明、截止时间、截止来源、优先级、优先级原因、置信度和摘要。人工纠正保存在本地，不会修改 Outlook 邮件。

9.6 转为待办

1. 选择“需要行动”队列中的邮件。
2. 点击 **转为待办**。
3. 工作台将行动说明作为待办标题，并带入优先级、截止日期、AI 摘要和原邮件链接。
4. 系统将该邮件的本地状态标记为已转换。
5. 页面会跳转到“行动中心 → 待办”。

同一邮件重复转换时，工作台会返回已有待办，避免重复创建。

9.7 生成回复草稿

1. 选择一封尚未处理的“需要行动”邮件。
2. 点击 **生成回复草稿**。
3. 选择语气：
 - 正式简洁；
 - 温和友好；
 - 直接行动。
4. 点击“生成草稿”或“重新生成”。
5. 在文本框中人工检查并编辑草稿。
6. 点击 **复制草稿**。
7. 打开 Outlook 原邮件，粘贴到回复框中。
8. 重新核对收件人、事实、日期、附件和承诺后，再人工发送。

[配图占位 20：AI 回复草稿弹窗——突出语气选择、草稿编辑区和“复制草稿”；建议图注“生成并人工确认回复草稿”；草稿内容必须使用虚构示例。]

安全提示： 回复草稿不会写入 Outlook，也不会自动发送。草稿会缓存到本地 SQLite 数据库 `.local/workbench.sqlite`。请按本机数据安全要求保护该文件。

9.8 标记处理、忽略与恢复

- “需要行动”邮件可标为“无需处理”；
- 信息类邮件可标记“已处理”；
- 已处理、忽略或转换的记录进入本地归档；
- 在支持恢复的界面中可将本地状态恢复为 `open`。

以上操作只改变工作台中的状态，不会给 Outlook 邮件设置已读、旗标、分类或移动文件夹。

10. 同步机制与数据安全

10.1 同步机制

- 首次同步范围：最近 7 天收件箱。
- 后续同步：基于最近成功同步时间进行增量读取，并保留少量时间重叠以避免漏信。
- 自动同步间隔：15 分钟。
- Graph 分页大小：每页最多 50 封。
- 单次同步检查上限：500 封。
- 本地保留的 Outlook 消息状态上限：500 条。
- AI 分类失败的邮件会进入“无法判断”，并保留失败状态供后续重试或人工确认。

10.2 邮件正文处理

工作台会对 Outlook 返回的正文执行以下处理：

1. 去除 HTML 标签、样式和脚本；
2. 规范空格与换行；
3. 尝试在“原始邮件”“发件人”“On ... wrote”等历史回复标记处截断；
4. 调用 DeepSeek 分类时，最多使用约 12,000 个字符；
5. 写入加密 Outlook 状态供界面展示时，清洗后的正文文本最多保留约 8,000 个字符。

因此，“原始 HTML 正文不直接落盘”不等于“本地完全不保存邮件文本”。当前实现会在加密 Outlook 状态中保存清洗后的正文摘录。

10.3 本地数据位置

数据	位置	保护方式
OAuth 访问/刷新令牌	<code>.local/outlook/state.enc.json</code>	AES-256-GCM 加密
隐私同意、同步游标、分类状态、清洗后的正文摘录	<code>.local/outlook/state.enc.json</code>	AES-256-GCM 加密
邮件摘要镜像、待办、AI 回复草稿等	<code>.local/workbench.sqlite</code>	本地 SQLite，依赖操作系统文件权限
环境变量和 API Key	<code>.env</code>	明文配置文件，依赖操作系统文件权限

`.env` 和 `.local/` 已按项目约定排除在版本控制之外，但仍应定期检查，避免被手工强制提交、复制到公共网盘或包含在不安全的诊断包中。

10.4 最小权限说明

委托式 `Mail.Read` 允许读取当前登录用户邮箱，包括正文；它不允许：

- 发送邮件；
- 删除或移动邮件；
- 修改已读状态或旗标；
- 读取整个组织所有人的邮箱。

不要为了处理授权问题而添加 `Mail.Readwrite`、`Mail.Send` 或应用程序级 `Mail.Read`。

10.5 密钥与备份建议

- 将 `.env` 和数据备份放在受控、加密的位置。
 - 备份 `.local/outlook/state.enc.json` 时必须同时可靠保管对应的 `OUTLOOK_TOKEN_ENCRYPTION_KEY`。
 - 不要把密钥直接写进操作文档、截图或源代码。
 - 调试日志中如意外出现令牌、授权码或设备码，应立即停止分享并按组织流程处理泄露。
 - 若电脑多人共用，应通过 Windows 账号权限限制项目目录的访问。
-

11. 断开、重连与彻底重置

11.1 断开 Outlook

1. 进入邮件处理页面。
2. 点击 **断开连接**。
3. 阅读确认提示。
4. 点击确认。

断开后：

- 本地连接令牌会被清除；
- 同步游标和最近同步状态会重置；
- 后续自动同步因没有连接而无法拉取邮件；
- 已保存在本地的邮件分类和归档记录仍然保留。

断开工作台连接不一定等于撤销 Microsoft 账号侧的应用同意。如需彻底撤销授权，应由用户或管理员在 Microsoft 账号/企业应用的授权管理中撤销该应用访问权。

11.2 重新连接

1. 确认 `.env` 中的客户端 ID、租户、回调地址和加密密钥未改变。
2. 保持工作台运行。
3. 打开 `http://127.0.0.1:5174/mail-setup`。
4. 重新确认隐私说明。
5. 使用标准浏览器授权或设备码授权。
6. 连接成功后会重新执行首次同步逻辑。

11.3 加密密钥错误时的彻底重置

当日志或页面提示“Outlook 本地状态无法解密，请检查加密密钥”，优先寻找并恢复原始 `OUTLOOK_TOKEN_ENCRYPTION_KEY`。

只有在确认原密钥无法恢复、并接受丢失本地 Outlook 状态时，才执行彻底重置。

高风险操作：删除前必须阅读

删除 `.local/outlook/state.enc.json` 会永久丢失本地保存的 Outlook 令牌、隐私同意记录、同步游标、邮件分类、人工纠正和 Outlook 本地归档。该操作不可通过工作台撤销。AI 回复草稿等 SQLite 数据不在这个文件中，但可能引用已不存在的 Outlook 消息。执行前应先创建备份。

安全重置步骤：

1. 在运行工作台的终端按 `Ctrl+C`，确认前后端已停止。
2. 确认当前目录是项目根目录：

```
1 | Get-Location
```

3. 确认目标文件存在且路径正确：

```
1 | Get-Item -LiteralPath .local\outlook\state.enc.json
```

4. 创建带时间戳的备份目录：

```
1 $backupDir = Join-Path (Get-Location) ("outlook-state-backup-" + (Get-Date -Format "yyyyMMdd-HH:mm:ss"))
2 New-Item -ItemType Directory -Path $backupDir
3 Copy-Item -LiteralPath .local\outlook\state.enc.json -Destination $backupDir
```

5. 核对备份文件存在：

```
1 Get-ChildItem -LiteralPath $backupDir
```

6. 将原状态文件改名，而不是直接永久删除：

```
1 Move-Item -LiteralPath .local\outlook\state.enc.json -Destination .local\outlook\state.enc.json.unreadable
```

7. 在 `.env` 中配置一个新的有效 32 字节 Base64 密钥。

8. 执行 `npm run dev`。

9. 打开 `/mail-setup`，重新完成隐私确认和 Outlook 授权。

10. 验证同步正常后，再按组织保留策略处理备份和 `.unreadable` 文件。

这里采用“备份 + 改名”的可恢复方式，避免误删后无法排查。

12. 故障排查

12.1 页面提示 Outlook 未配置

现象

- `/mail-setup` 显示“完成 Outlook 本地配置”；
- 页面列出一个或多个缺失变量。

常见原因

- `OUTLOOK_ENTRA_CLIENT_ID` 为空；
- `OUTLOOK_OAUTH_REDIRECT_URI` 为空；
- `OUTLOOK_TOKEN_ENCRYPTION_KEY` 不是有效的 32 字节 Base64；
- `DEEPSEEK_API_KEY` 为空；
- 修改 `.env` 后没有重启服务。

检查

1. 对照 `.env.example` 检查变量名拼写。
2. 确认 `.env` 位于项目根目录。
3. 确认没有把模板占位值当成真实密钥。
4. 重启 `npm run dev`。

解决

补齐页面列出的变量，生成有效加密密钥，保存 `.env` 后重启服务。

12.2 AADSTS50011：回复 URL 不匹配

现象

Microsoft 登录页显示类似：

```
1 | AADSTS50011: The reply URL specified in the request does not match...
```

原因

授权请求中的 `redirect_uri` 与 Entra 中登记的 URI 不完全一致。

检查

逐字符核对以下三个位置：

1. `.env` 的 `OUTLOOK_OAUTH_REDIRECT_URI`；
2. Entra“身份验证 → 移动和桌面应用程序”的重定向 URI；
3. 实际前端端口。

解决

统一为：

```
1 | http://127.0.0.1:5174/api/outlook/oauth/callback
```

如使用其他端口，三处同时修改。修改 `.env` 后重启工作台，再重新发起授权。

12.3 设备码连接失败或不显示设备码

现象

- 提示“无法获取 Microsoft 设备码”；
- Microsoft 返回不允许公共客户端的错误；
- 设备码页面一直失败。

原因

- “允许公共客户端流”未开启；
- Entra 设置没有保存；
- 网络无法访问 `login.microsoftonline.com`；
- 客户端 ID 或租户不正确。

解决

1. 在 Entra“身份验证 → 高级设置”确认“允许公共客户端流 = 是”。
2. 保存并刷新 Entra 页面。
3. 检查客户端 ID 和租户设置。
4. 查看工作台启动日志中的网络探测结果。
5. 重新获取设备码。

12.4 设备码过期、会话不存在或授权被拒绝

现象

- “设备码已过期，请重新获取”；
- “设备码会话不存在”；
- “Microsoft 授权被拒绝”。

原因

- 超过设备码有效期；
- 工作台后端重启，内存中的设备码会话丢失；
- 用户在 Microsoft 页面点击了拒绝；
- 工作台页面刷新或长时间闲置。

解决

保持后端和页面运行，重新点击“设备码连接”，使用新代码完成授权。

12.5 标准授权回调失败或授权会话过期

现象

- 回调页显示“Outlook 授权响应缺少授权码”；
- 提示“授权会话已过期，请重新连接”；
- 浏览器回跳后无法连接 127.0.0.1。

原因

- 授权超过 10 分钟；
- 后端在授权过程中重启；
- 前端端口或代理未运行；
- 防火墙/浏览器阻止本机回调。

解决

1. 确认 `npm run dev` 仍在运行。
2. 重新打开 `/mail-setup` 发起授权。
3. 在 10 分钟内完成登录。
4. 仍无法回跳时改用设备码授权。

12.6 提示“需要管理员批准”

现象

Microsoft 登录页不允许用户自行同意。

原因

组织租户禁止用户同意第三方或未验证应用，或条件访问策略要求审批。

解决

请租户管理员审核：

- 应用注册是否属于正确租户；
- 权限是否仅为委托式 `Mail.Read`；
- 是否可代表租户授予管理员同意；
- 企业应用是否被禁用；
- 条件访问是否阻止当前用户或设备。

不要添加更高权限作为替代方案。

12.7 授权成功但 Graph 无法读取邮箱

现象

- 页面显示“无法读取 Microsoft Graph 邮箱数据”；
- 同步返回 502；
- 最近同步没有更新。

可能原因

- 网络无法访问 `graph.microsoft.com`；
- 令牌过期且刷新失败；
- `Mail.Read` 未正确同意；
- 账号没有可用的 Exchange Online 邮箱；
- 租户策略限制 Graph；
- 代理配置失效。

检查与解决

1. 查看后端日志是否包含 Microsoft Graph、token 或网络错误。
2. 在 Entra 中确认 `Mail.Read` 类型为 Delegated。
3. 确认该账号能在 Outlook 网页正常打开邮箱。
4. 检查代理软件和 `HTTP_PROXY / HTTPS_PROXY`。
5. 断开后重新授权。
6. 如仍失败，由管理员检查登录日志、条件访问和企业应用状态。

12.8 DeepSeek 分类失败

现象

- 页面显示“DeepSeek 邮件分类请求失败”；
- 邮件进入“无法判断”；
- 日志显示 HTTP 401、403、429、余额不足、模型不存在或返回内容为空。

可能原因

- API Key 错误或过期；
- 账户额度不足；
- 模型名称不支持；
- 网络或代理无法访问 DeepSeek；

- 推理模型输出耗尽 token 预算；
- DeepSeek 服务暂时异常。

解决

1. 核对 `DEEPSEEK_API_KEY`、`DEEPSEEK_BASE_URL` 和 `DEEPSEEK_MODEL`。
2. 在 DeepSeek 控制台检查额度和 Key 状态。
3. 默认优先使用 `deepseek-chat`。
4. 修改 `.env` 后重启服务。
5. 网络恢复后再次点击“立即同步”；失败邮件会进入人工确认或后续重试流程。

12.9 fetch failed、ECONNRESET 或登录页打不开

现象

- 后端日志出现 `fetch failed`、`ECONNRESET`；
- 登录页 `ERR_CONNECTION_CLOSED`；
- Microsoft 和 DeepSeek 请求同时失败。

可能原因

- 系统残留了已关闭代理的环境变量；
- 代理端口变化；
- 代理规则拒绝 Microsoft；
- 公司网络或防火墙限制；
- TUN 模式与显式代理设置冲突。

检查

```
1 | Get-ChildItem Env:HTTP_PROXY,Env:HTTPS_PROXY,Env:ALL_PROXY -ErrorAction SilentlyContinue
```

查看启动日志：

- “经代理”表示代理探测成功；
- “代理不可用，但直连可达”表示已自动回退；
- “代理与直连均无法访问 Microsoft”表示需要处理网络出口。

解决

修正或清理失效的代理环境变量，确认浏览器和 Node.js 均能访问 Microsoft 登录端点，然后重启工作台。标准授权受浏览器限制时可以尝试设备码，但后端仍必须能访问 Microsoft token 端点和 Graph。

12.10 Outlook 本地状态无法解密

现象

```
1 | outlook 本地状态无法解密。请检查加密密钥。
```

原因

- `OUTLOOK_TOKEN_ENCRYPTION_KEY` 被修改；
- `.env` 使用了另一台机器的密钥；
- 状态文件来自其他环境；
- 状态文件损坏。

解决顺序

1. 优先恢复创建状态文件时使用的原密钥。
2. 确认 `.env` 没有多余空格、引号或换行。
3. 重启服务再验证。
4. 原密钥无法恢复时，按 [11.3 加密密钥错误时的彻底重置](#) 备份并重建状态。

12.11 同步不到旧邮件

现象

连接正常，但看不到 7 天以前的邮件。

原因

当前实现首次同步只读取最近 7 天，并且单次最多检查/保留 500 封。

解决

这属于当前产品范围，不是配置错误。若业务确实需要更长历史周期，应提交产品/开发变更，而不是通过增加 Graph 权限解决。

12.12 打开原邮件跳转不准确

现象

点击“打开原邮件”后进入 Outlook 搜索页，或搜索到多封同名邮件。

原因

Microsoft Graph 返回的 `webLink` 缺失时，工作台会退化为按主题搜索。

解决

结合发件人和收到时间人工确认目标邮件；同步网络恢复后重新同步，检查 Graph 是否返回 `webLink`。

13. 最终验收清单

13.1 管理员配置验收

- ☐ Entra 应用创建在正确租户中。
- ☐ 已记录正确的 Application (client) ID，而不是 Object ID。
- ☐ 支持的帐户类型与团队用户范围一致。
- ☐ 已添加“移动和桌面应用程序”平台。
- ☐ 重定向 URI 与 `.env` 完全一致。
- ☐ “允许公共客户端流”已设为“是”并保存。

- ☐ Microsoft Graph 权限是委托式 `Mail.Read`。
- ☐ 未创建或使用 Client Secret。
- ☐ `.env` 中已填写 Client ID、租户、回调地址、有效加密密钥和 DeepSeek Key。
- ☐ `USE_DEMO_DATA=false`。
- ☐ `.env` 与 `.local/` 未提交到版本库。

13.2 运行环境验收

- ☐ `npm install` 完成且没有阻塞性错误。
- ☐ `npm run dev` 同时启动前端和后端。
- ☐ 前端可访问 `http://127.0.0.1:5174`。
- ☐ 后端监听 `http://127.0.0.1:8787`。
- ☐ 启动日志显示 Microsoft 网络探测可用。
- ☐ 设置页不再提示 Outlook 必要配置缺失。

13.3 用户授权验收

- ☐ 用户阅读并确认邮件数据处理说明。
- ☐ 标准浏览器授权或设备码授权完成。
- ☐ Microsoft 权限页只出现预期的读取邮件与保持访问范围。
- ☐ 工作台显示 Outlook 已连接。
- ☐ 首次同步完成且最近同步时间已更新。

13.4 功能验收

- ☐ 最近 7 天的收件箱邮件能够显示。
- ☐ 四个队列可以切换。
- ☐ 邮件摘要、行动建议、优先级和截止时间可见。
- ☐ “打开原邮件”可以工作。
- ☐ “无法判断”的邮件可以人工纠正。
- ☐ 邮件可以转为待办且不会重复创建。
- ☐ 回复草稿可以生成、编辑和复制。
- ☐ 回复草稿不会自动写入或发送到 Outlook。
- ☐ “立即同步”可以更新同步状态。
- ☐ 断开连接后本地归档仍然存在。

13.5 安全验收

- ☐ 文档和截图中没有真实 Client ID、租户 ID、API Key、令牌、授权码或设备码。
- ☐ `OUTLOOK_TOKEN_ENCRYPTION_KEY` 已由负责人安全保管。
- ☐ 运行电脑的项目目录仅对授权用户开放。
- ☐ 已明确清洗后的正文摘录和回复草稿会保存在本机。
- ☐ 高风险邮件仍要求人工核对后处理或发送。

14. Microsoft 官方参考资料

以下链接用于核对 Microsoft Entra 当前界面、公共客户端设置、重定向 URI 和 Graph 权限。门户名称调整时，应以 Microsoft 最新文档为准，同时保证项目实际发送的参数与 Entra 注册配置一致。

- [在 Microsoft Entra ID 中注册应用程序](#)
- [配置调用 Web API 的桌面应用](#)
- [重定向 URI（回复 URL）概述和限制](#)
- [Microsoft Graph 权限引用](#)
- [代表用户获取访问权限](#)

附录 A：最小配置快速参考

```
1 PORT=8787
2 PUBLIC_BASE_URL=http://localhost:5174
3 CORS_ORIGIN=http://localhost:5174
4
5 AI_PROVIDER=deepseek
6 DEEPSEEK_API_KEY=<真实 Key，不要提交>
7 DEEPSEEK_BASE_URL=https://api.deepseek.com
8 DEEPSEEK_MODEL=deepseek-chat
9
10 OUTLOOK_ENTRA_CLIENT_ID=<Application (client) ID>
11 OUTLOOK_ENTRA_TENANT_ID=common
12 OUTLOOK_OAUTH_REDIRECT_URI=http://127.0.0.1:5174/api/outlook/oauth/callback
13 OUTLOOK_TOKEN_ENCRYPTION_KEY=<32 字节随机数据的 Base64>
14
15 USE_DEMO_DATA=false
```

启动：

```
1 npm install
2 npm run dev
```

授权入口：

```
1 http://127.0.0.1:5174/mail-setup
```

日常邮件入口：

```
1 http://127.0.0.1:5174/actions?tab=email
```

附录 B：截图替换说明

本文所有截图占位符均使用以下格式：

```
1 > [配图占位 NN：页面名称—需突出显示的区域；建议图注“.....”；隐私处理要求。]
```

替换时建议：

1. 保留占位符中的“建议图注”，放在图片下方。
2. 截图宽度尽量一致，优先使用 PNG。
3. 对账号、邮箱、租户 ID、客户端 ID、API Key、令牌、邮件主题、正文和设备码进行打码。
4. 截图中若使用演示邮件，确保所有人名、公司名、金额和日期均为虚构数据。
5. 替换完成后删除对应占位符文字，避免图片和占位符同时存在。